Федеральное государственное автономное
образовательное учреждение высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность

Лабораторная работа №3

Аудит безопасности веб-приложения

Группа: P3411

Выполнила:

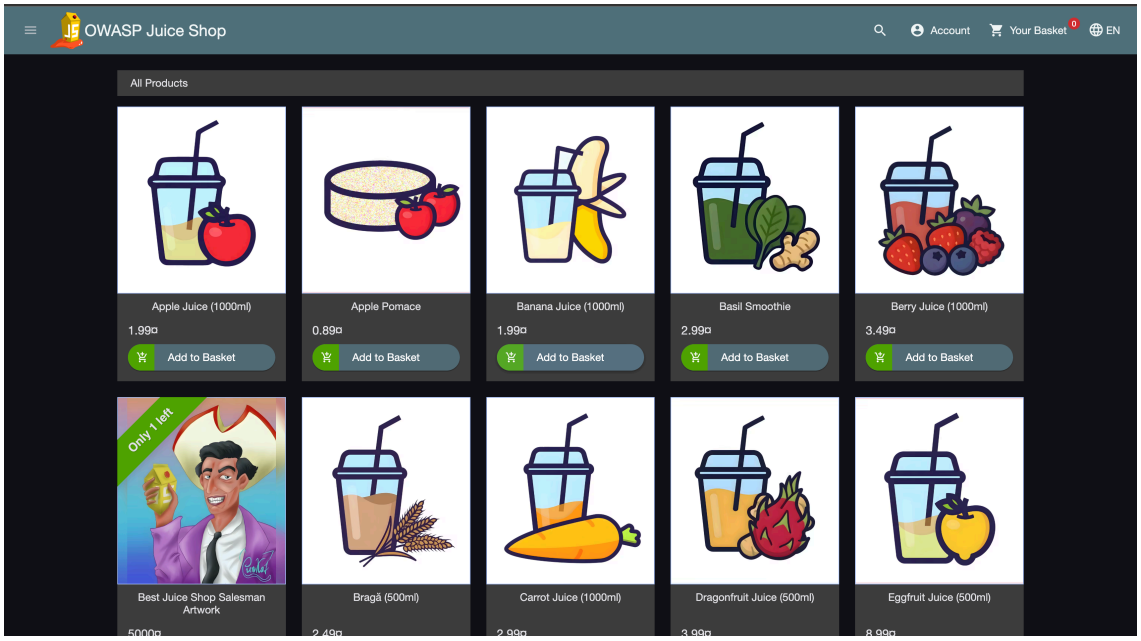
Денисова Алёна Александровна

г. Санкт-Петербург

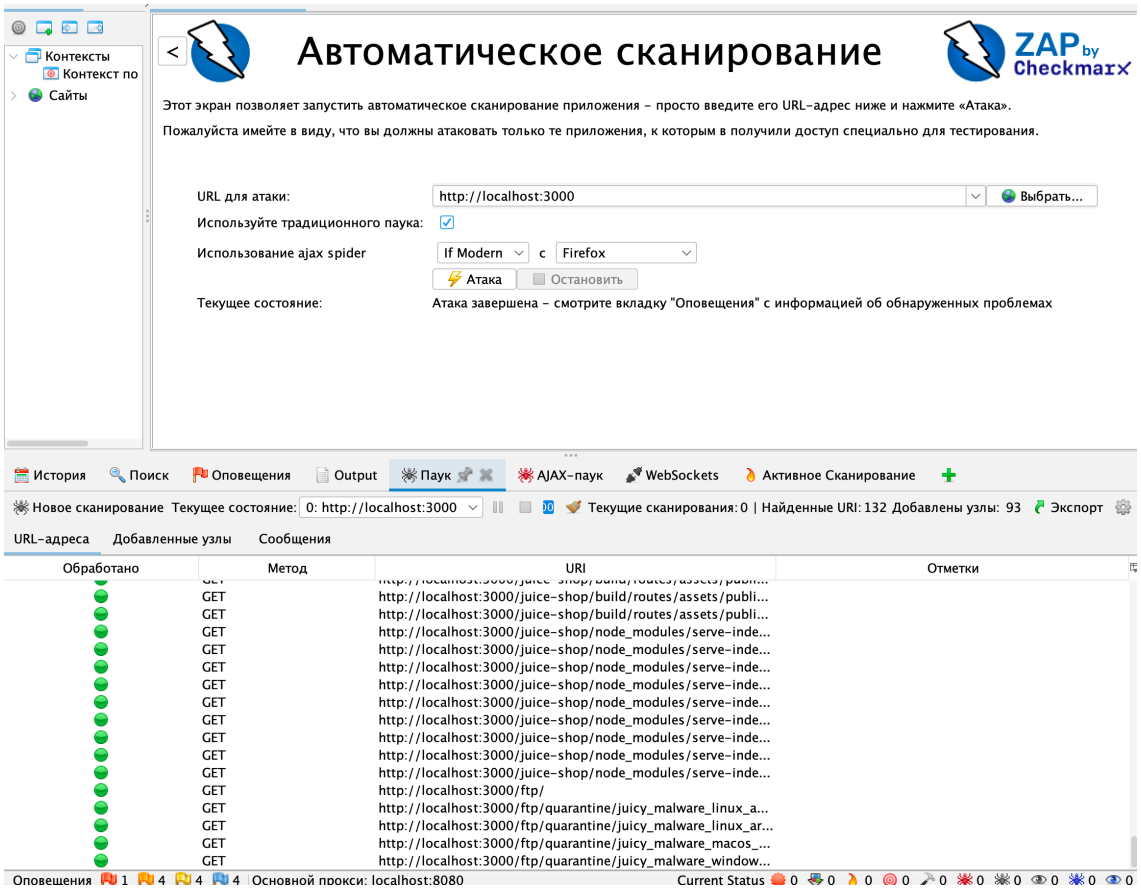
2026

Выполнение

Установлен и запущен Juice Shop:

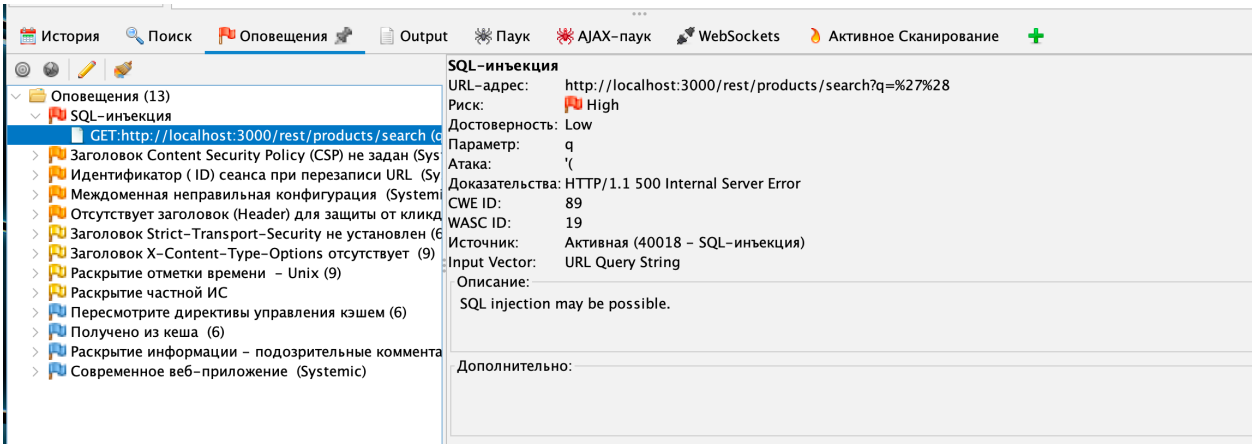


Запущена ZAP атака по URL http://localhost:3000:



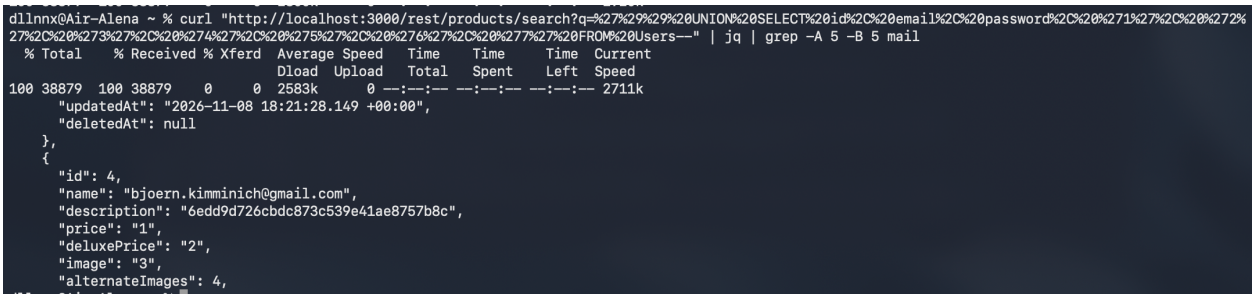
Анализ результатов

Отсортированная вкладка alerts:



Верификация найденных уязвимостей:

1. SQLi в строке поиска продуктов



Запрос:

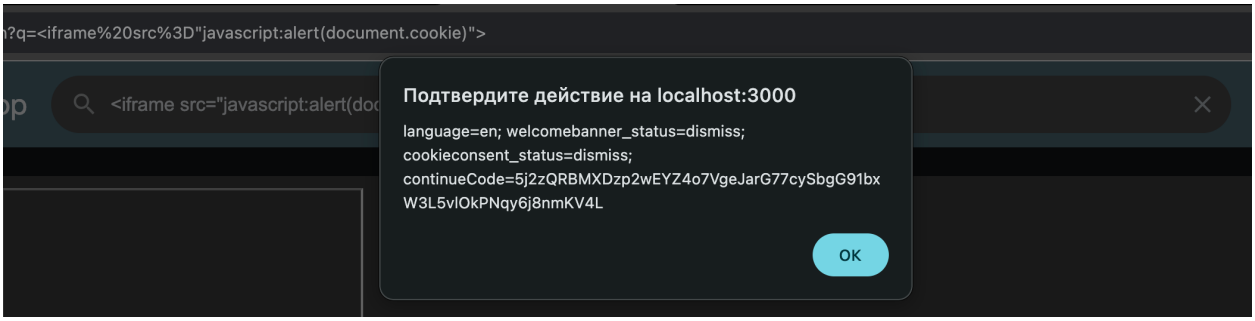
```
curl
"http://localhost:3000/rest/products/search?q=%27%29%29%20U
NION%20SELECT%20id%2C%20email%2C%20password%2C%20%271%27%2C
%20%272%27%2C%20%273%27%2C%20%274%27%2C%20%275%27%2C%20%276
%27%2C%20%277%27%20FROM%20Users--"
```

а то есть дописываем в поиск `')) UNION SELECT id, email, password, '1', '2', '3', '4', '5', '6', '7' FROM Users--`

Получилось достать id, name, хэш пароля пользователя.

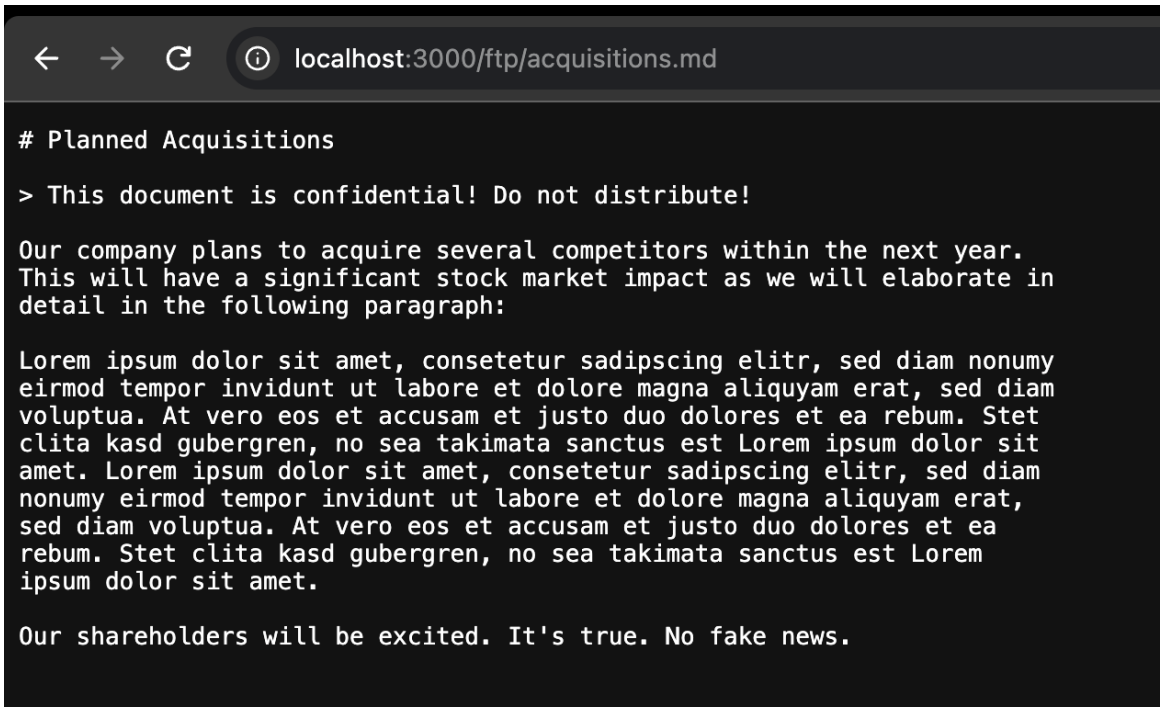
Уязвимостей XSS OWASP ZAP не выявил, поэтому демонстрирую найденную самостоятельно:

2. XSS в строке поиска продуктов



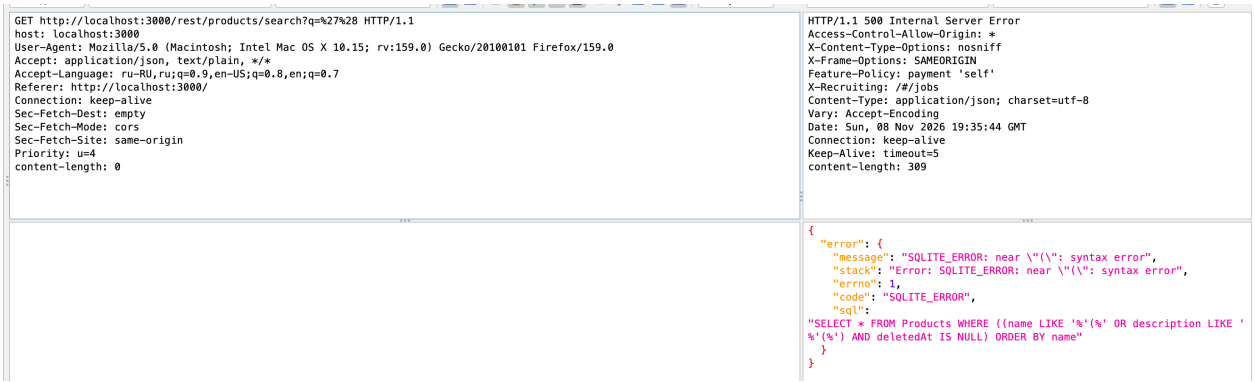
Достаточно вставить <iframe src="javascript:alert(document.cookie)"> в строку поиска.

3. Просмотр конфиденциальных документов



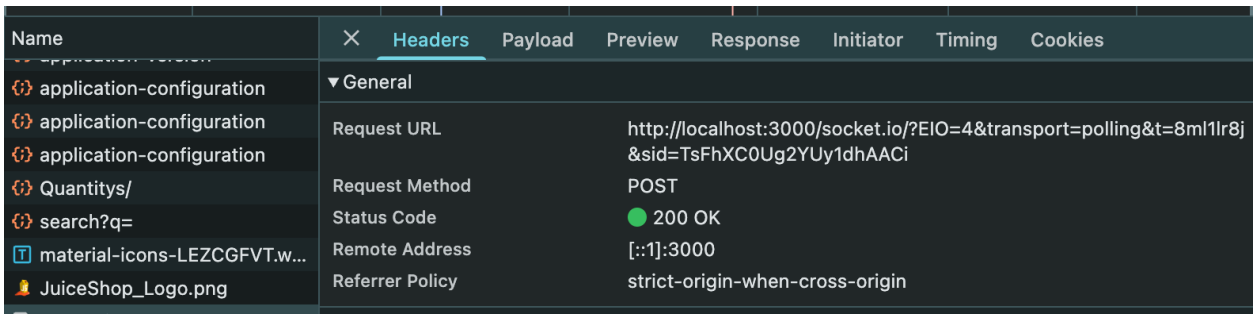
Атака ZAP выявила открытый эндпоинт /ftp, по которому можно просмотреть каталог с бизнес-файлами (в том числе те, которые помечены как “confidential”).

4. Раскрытие ошибок приложения



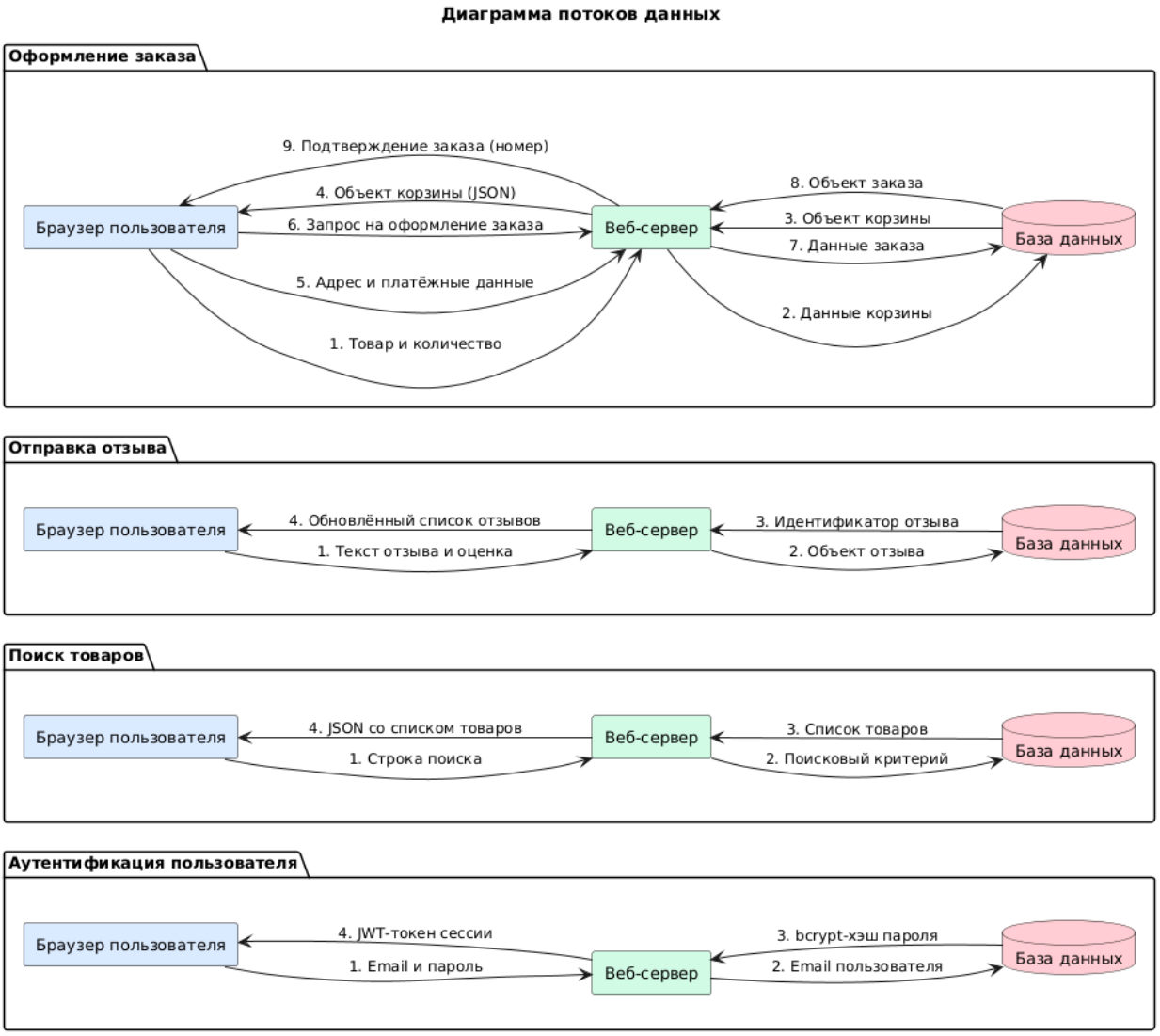
Раскрытые ошибки позволяют узнать информацию о деталях реализации приложения (движок БД, структура запроса) – это помогает атакующему.

5. Session ID в URL



Получив sid, злоумышленник сможет получать чужие входящие пакеты и отправлять сообщения от имени жертвы.

Диаграмма потока данных



Анализ угроз по методике STRIDE

S – Spoofing:

- На потоке данных «Аутентификация» через SQLi

T – Tampering:

- На потоке «Оформление заказов» подмена параметров корзины заменой тела HTTP запроса
- На потоке «Отправка отзыва» подмена имени автора путем замены тела HTTP запроса

R – Reduplication

- Возможно на всех потоках, если логи по заказам и пользователям не ведутся

I – Information disclosure

- На потоке «Поиск товаров» получение данные всех пользователей через SQLi
- На потоке «Поиск товара» получение cookie пользователей через XSS атаку
- Получение служебных файлов по открытому пути (/ftp)

D – Denial of Service

- На любом из потоков возможно «положить» сервис с помощью DDoS атаки

E - Elevation of Privilege

- На потоке «Аутентификация» вход под учетной записью администратора через SQLi
- На потоке «Создание заказа» просмотр корзину других пользователей через подмену тела HTTP запроса

Таблица уязвимостей

Название	Описание	Уровень риска (CVSS v3.0)	Категория OWASP Top 10	Предложение по исправлению
SQL-инъекция в поиске товаров	Параметр поискового запроса без обработки подставляется в SQL-запрос к БД. Через UNION SELECT атакующий объединяет результат с произвольной таблицей и извлекает данные пользователей.	9.8 Критический	A03:2021 - Injection	Параметризованные запросы вместо конкатенации строк; валидация ввода на сервере
SQL-инъекция в форме входа	Поле email формы входа конкатенируется в SQL-запрос. Подмена условия позволяет войти под первой учетной записью базы данных – администратором.	9.1 Критический	A07:2021 - Identification and Authentication Failures	Параметризованные запросы
XSS в поисковом запросе с кражей JWT-токена	Строка поиска вставляется в страницу результатов без экранирования: внедренный JavaScript выполняется в контексте доверенного сайта и может прочитать localStorage, где хранится JWT-токен сессии.	8.2 Высокий	A03:2021 - Injection	Экранирование вывода в контексте HTML; Content Security Policy; хранение токена в HttpOnly-cookie; валидация ввода на сервере.
Открытый листинг каталога /ftp	Каталог /ftp доступен без аутентификации: отдаётся список файлов с внутренними документами, часть файлов скачивается напрямую.	7.5 Высокий	A01:2021 - Broken Access Control	Отключить листинг каталогов; хранить файлы вне веб-корня; закрыть доступ аутентификацией и правами
XSS в отзывах на товары	Пользовательский контент отзыва вставляется в страницу товара без экранирования: внедренный скрипт сохраняется и выполняется у каждого посетителя карточки товара.	5.8 Средний	A03:2021 - Injection	Валидация пользовательского контента на сервере; экранирование вывода; Content Security Policy.
Раскрытие диагностической информации в ошибках	При некорректном вводе сервер возвращает HTTP 500 с деталями внутренней ошибки: тип и сообщения СУБД, фрагменты структуры SQL-запроса. Информация помогает атакующему готовить целевые атаки.	5.3 Средний	A05:2021 - Security Misconfiguration	Пользовательские страницы ошибок без технических деталей; логирование деталей только на сервере
ID сессии в URL	Параметр sid передаётся в query-строке URL: идентификатор попадает в логи, историю браузера и Referer. Знание sid позволяет перехватывать сообщения канала и отправлять их от имени жертвы.	4.1 Средний	A07:2021 - Identification and Authentication Failures	Передавать идентификатор сессии в заголовках или теле, а не в URL; Referrer-Policy: no-referrer

Общие рекомендации

- Использовать параметризованные запросы при обращении к БД – пользовательский ввод не должен конкатенироваться с текстом SQL-запроса
- Использовать экранирование и валидацию пользовательского ввода
- Внедрить строгую политику CSP и настроить защитные HTTP-заголовки (X-Frame-Options, X-Content-Type-Options)
- Настроить единую обработку ошибок без вывода служебной информации
- Проектировать систему по принципу минимальных привилегий

Отчет OWASP ZAP

https://github.com/dllnnx/ib/blob/main/ib-3/2026-11-09-ZAP-Report-.html